

# Lab- Vulnerability scan using OWASP ZAP

***Note: This lab was performed based on the lab work provided in “Module 6.12: Exploiting Insecure Code Practices” in the “Ethical Hacking” Course provided by CISCO.***

The **Open Worldwide Application Security Project (OWASP)** is a nonprofit foundation that developed the Web Security Testing Guide (WSTG) to test the most common web application security issues. In this lab, we will conduct a vulnerability scan using the Zed Attack Proxy (ZAP).

## Objectives

In this lab, we will complete the following objectives:

- Scan a Website Using ZAP
- Investigate Vulnerability References

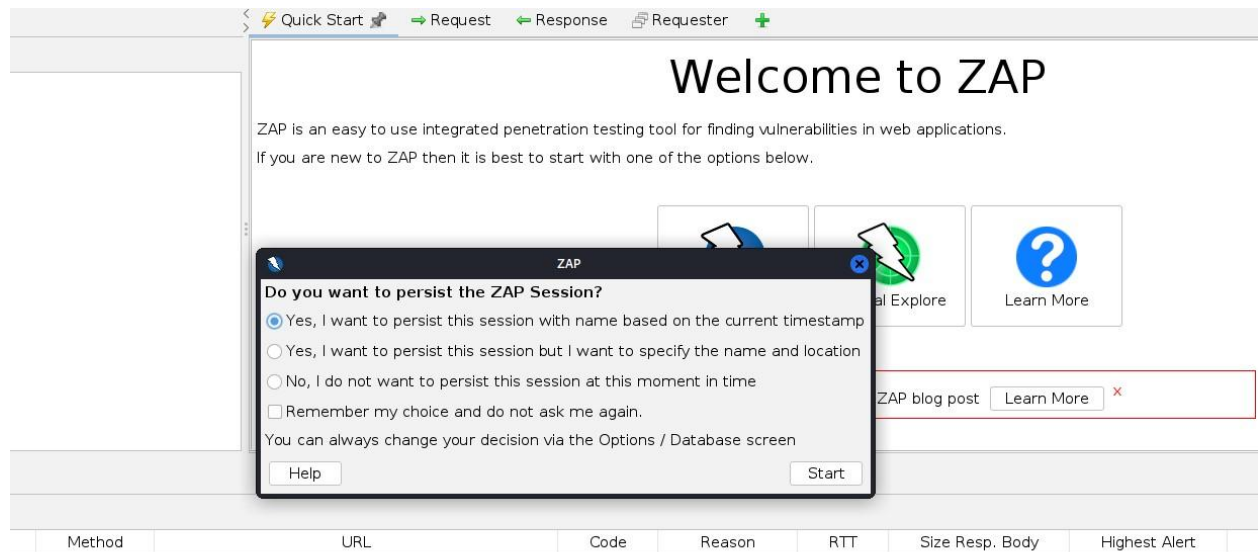
## Required Resources

- Kali VM customized for the Ethical Hacker course
- Internet access

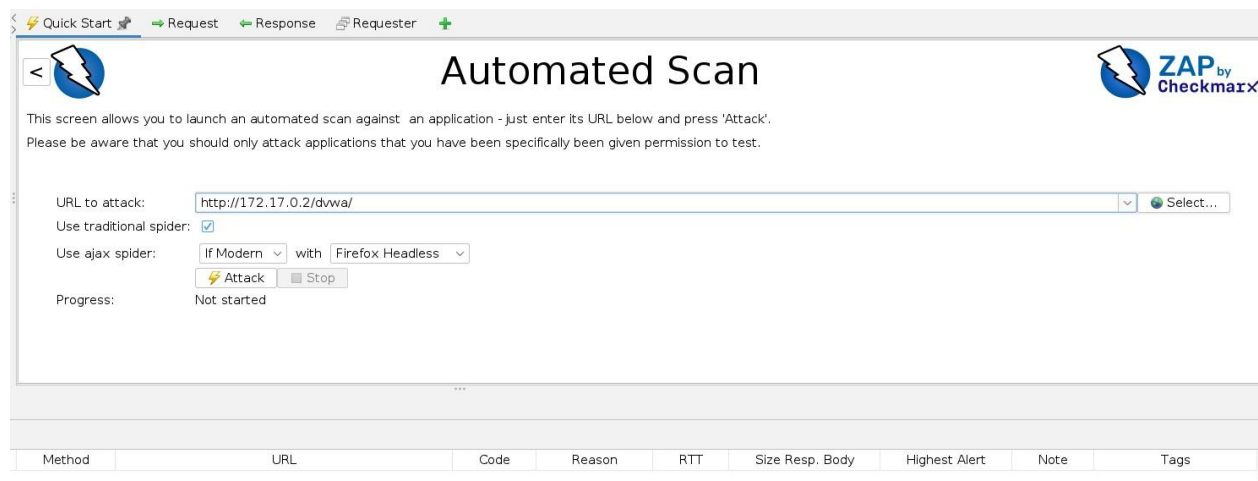
## Part 1- Scan using the Zed Attack Proxy (ZAP)

At first, we will scan the target website using ZAP to find out the vulnerabilities that may reside on the targeted web application.

- a. As already mentioned in the required resources section, start the Kali VM first. Next, navigate to the Kali menu and search for zap to start the OWASP Zap scanner.
- b. If the pop-up screen appears, click the topmost radio button to persist the session. This means that we can return to the session at a later time.

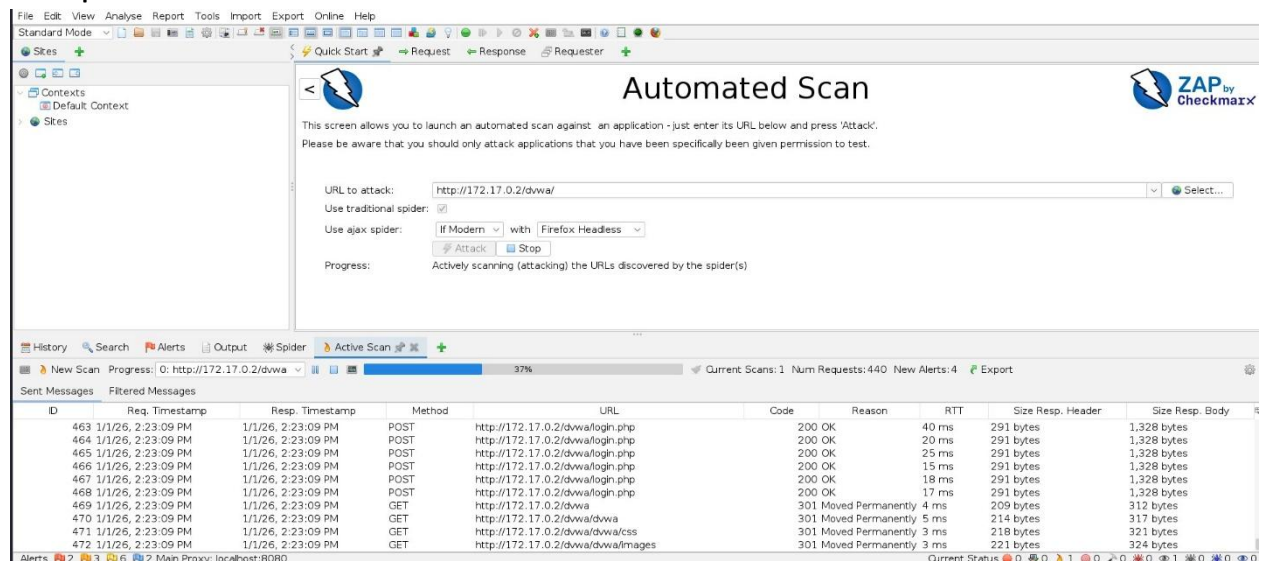


- c. Close the **Manage Add-ons** dialog window if it appears.
- d. In the ZAP main window, click on the big **“Automated Scan”** button to initiate a scan.



- e. In the URL to Attack field, enter the IP or the URL that needs to be tested. In this lab, we use **172.17.0.2/dvwa** for scanning.

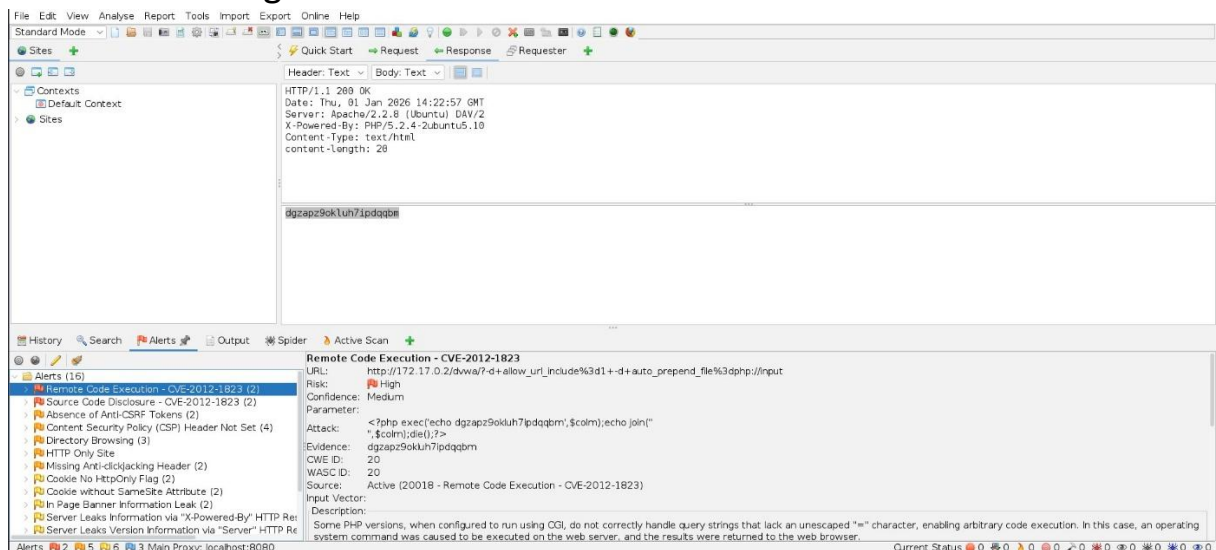
- f. To begin the scan, click the **Attack** button. The scan takes a few minutes to complete.



## Part 2- Investigate the results

After the scanning is completed, we will now investigate the scan results generated by ZAP.

- For this part, select the Alerts tab at first if it is not already selected. When the scan finishes, you will be automatically switched there.
- Next, locate and click the Remote Code Execution – **CVE-2012-1823** alert and scroll through the details of the alert.



- c. Scroll down to the **Alert Tags** section of the vulnerability and then note the WSTG key and value displayed there. We can also click the value and use the **Ctrl-C** keys to copy the URL to the clipboard.

The screenshot shows a vulnerability report from a tool called 'Active Scan'. The report details a 'Remote Code Execution' vulnerability (CVE-2012-1823) in PHP versions that do not correctly handle query strings with unescaped '=' characters. It provides a description, a solution (upgrade PHP or use mod\_rewrite), and references. The 'Alert Tags' section contains a table with two columns: 'Key' and 'Value'. The keys listed are POLICY\_QA\_FULL, OWASP\_2021\_A06, POLICY\_PENTEST, WSTG-v42-INPV-12, and CVE-2012-1823. The value for WSTG-v42-INPV-12 is highlighted in blue and contains the URL: [https://owasp.org/www-project-web-security-testing-guide/v42/4-Web\\_Application\\_Security\\_Testing/07-Input\\_Validation\\_Testing/12-Testing\\_for\\_Command\\_Injection](https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/07-Input_Validation_Testing/12-Testing_for_Command_Injection).

| Key              | Value                                                                                                                                                                                                                                                                                                                                   |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| POLICY_QA_FULL   |                                                                                                                                                                                                                                                                                                                                         |
| OWASP_2021_A06   | <a href="https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/">https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/</a>                                                                                                                                                                                 |
| POLICY_PENTEST   |                                                                                                                                                                                                                                                                                                                                         |
| WSTG-v42-INPV-12 | <a href="https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/07-Input_Validation_Testing/12-Testing_for_Command_Injection">https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/07-Input_Validation_Testing/12-Testing_for_Command_Injection</a> |
| CVE-2012-1823    | <a href="https://nvd.nist.gov/vuln/detail/CVE-2012-1823">https://nvd.nist.gov/vuln/detail/CVE-2012-1823</a>                                                                                                                                                                                                                             |

- d. Now, open a browser and paste the URL in the address bar of the browser. It will be navigated to the WSTG site. Read about the vulnerability and methods of testing for it.

The screenshot shows the OWASP website for the Web Security Testing Guide (WSTG) v4.2. The browser address bar shows the URL: [https://owasp.org/www-project-web-security-testing-guide/v42/4-Web\\_Application\\_Security\\_Testing/07-Input\\_Validation\\_Testing/12-Testing\\_for\\_Command\\_Injection](https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/07-Input_Validation_Testing/12-Testing_for_Command_Injection). The page has a green header with the OWASP logo and navigation links. Below the header, there's a section for 'WSTG - v4.2' with a breadcrumb trail: Home > V42 > 4-Web Application Security Testing > 07-Input Validation Testing. The main heading is 'Testing for Command Injection'. Below this, there's a table with one row: ID | WSTG-INPV-12. The 'Summary' section describes the article's content: 'This article describes how to test an application for OS command injection. The tester will try to inject an OS command through an HTTP request to the application. OS command injection is a technique used via a web interface in order to execute OS commands on a web server. The user supplies operating system commands through a web interface in order to execute OS commands. Any web interface that is not properly sanitized is subject to this exploit. With the ability to execute OS commands, the user can upload malicious programs or even obtain passwords. OS command injection is preventable when security is emphasized during the design and development of applications.' The 'Test Objectives' section is also visible. On the right side, there's a sidebar with a description of the OWASP Foundation and a 'WSTG Contents (v4.2)' table of contents listing various sections like Foreword, Frontispiece, Introduction, and specific testing techniques.

## WSTG - v4.2

Home > V42 > 4-Web Application Security Testing > 07-Input Validation Testing

### Testing for Command Injection

| ID           |
|--------------|
| WSTG-INPV-12 |

#### Summary

This article describes how to test an application for OS command injection. The tester will try to inject an OS command through an HTTP request to the application.

OS command injection is a technique used via a web interface in order to execute OS commands on a web server. The user supplies operating system commands through a web interface in order to execute OS commands. Any web interface that is not properly sanitized is subject to this exploit. With the ability to execute OS commands, the user can upload malicious programs or even obtain passwords. OS command injection is preventable when security is emphasized during the design and development of applications.

#### Test Objectives

**The OWASP® Foundation** works to improve the security of software through its community-led open source software projects, hundreds of chapters worldwide, tens of thousands of members, and by hosting local and global conferences.

#### WSTG Contents (v4.2)

- 0. Foreword by Eoin Keary
- 1. Frontispiece
- 2. Introduction
- 2.1 The OWASP Testing Project
- 2.2 Principles of Testing
- 2.3 Testing Techniques Explained
- 2.4 Manual Inspections and Reviews
- 2.5 Threat Modeling
- 2.6 Source Code Review
- 2.7 Penetration Testing
- 2.8 The Need for a Balanced Approach
- 2.9 Deriving Security Test Requirements
- 2.10 Security Tests Integrated in Development and Testing Workflows